SAMPLE REPORT

API & Web Application Penetration Test

Prepared for a fictional customer, **ExampleCo Billing**, to show the structure and level of detail of an Xarmoured report.

Field	Value
Target (fictional)	app.exampleco.test, api.exampleco.test
Assessment type	Web application and API, authenticated, grey-box
Testing window	Illustrative: 5 working days
Report version	Sample 1.0
Classification	Confidential (sample)

This is an illustration. It is not a real engagement and contains no client data. Findings are invented to show how evidence, impact and remediation are presented.

1. Executive summary

Xarmoured assessed the ExampleCo Billing web application and REST API using two test accounts in separate customer organisations. Testing focused on authentication, authorization, business logic and data exposure.

One **High** severity authorization flaw allows an authenticated user to read invoices belonging to other organisations. Two lower-severity issues were also reported. No testing was performed outside the agreed scope.

Severity	Count	Meaning
Critical	0	Direct, easily exploited compromise of the system or all customer data
High	1	Serious impact on confidentiality or integrity, exploitable with low effort
Medium	1	Meaningful weakness that needs specific conditions
Low	1	Limited impact or defence-in-depth gap

Findings overview

ID	Title	Severity	Status
XA-001	Broken object-level authorization on invoice API	High	Open
XA-002	No rate limiting on password login	Medium	Open
XA-003	Missing security headers on web app	Low	Open

2. Scope and methodology

In scope: app.exampleco.test and api.exampleco.test (production-like staging). **Out of scope:** denial-of-service testing, social engineering, third-party payment provider.

The approach follows the Xarmoured engagement flow: **scope, map, test, validate, report, remediate, retest**. Tools help coverage, but findings in this report were confirmed manually and reproduced before being reported.

Limitations. Testing covers the time window and accounts provided. The absence of a finding is not proof that no weakness exists. Results reflect the application at the time of testing.

3. Detailed findings

XA-001 · Broken object-level authorization on invoice API

Severity	High
Affected	GET /api/v1/invoices/{id}
Category	Broken object-level authorization (BOLA / IDOR)
Preconditions	Any authenticated user

Description. The invoice endpoint verifies that the caller is logged in but does not check that the requested invoice belongs to the caller's organisation. Sequential invoice IDs make other organisations' invoices easy to enumerate.

Reproduction (fictional).

```
1. Log in as user-A (Org A) and note an own invoice ID: 1042.
2. Request an invoice owned by Org B:

   GET /api/v1/invoices/1043
   Authorization: Bearer <user-A token>

3. Observe HTTP 200 containing Org B customer name, address
   and line items.
```

Impact. Any customer can read other customers' billing data, which is a confidentiality and privacy failure across tenant boundaries.

Recommendation. Resolve the invoice server-side and enforce that its organisation matches the caller's organisation on every request. Return 404 for non-owned objects. Replace sequential IDs with non-guessable identifiers as defence in depth, and add an automated cross-tenant test.

XA-002 · No rate limiting on password login

Severity	Medium
Affected	POST /api/v1/auth/login
Category	Authentication / brute force protection

Description. Repeated failed logins for one account were not slowed, blocked or flagged. In the sample, 200 attempts completed without a lockout or challenge.

Recommendation. Add per-account and per-IP throttling with progressive delay, alert on repeated failures, and consider multi-factor authentication for sensitive roles.

XA-003 · Missing security headers

Severity	Low
Affected	app.exampleco.test responses

Description. Responses lacked a Content-Security-Policy and clickjacking protection. No direct exploit was demonstrated, so impact is limited.

Recommendation. Add a restrictive CSP, `frame-ancestors` (or `X-Frame-Options`) and `X-Content-Type-Options: nosniff`.

4. Retest results (illustrative)

After remediation, Xarmoured re-runs the original attack path against the fixed system and records one of three outcomes: **resolved**, **partially resolved** or **still reproducible**.

ID	Original severity	Retest result	Notes
XA-001	High	Resolved	Cross-tenant requests now return 404. Bypass attempts using alternate endpoints and ID formats failed.
XA-002	Medium	Partially resolved	Per-IP throttling added; per-account lockout still missing.
XA-003	Low	Resolved	Headers present on all tested routes.

What this sample shows

Every finding states what was affected, how to reproduce it, why it matters and how to fix the cause. A retest then confirms the fix against the original attack path. To see how your own scope would be reported, **request an assessment at xarmoured.tech/assessment**.